

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

MONDAY, FEBRUARY 23, 2009

Top Ten Web Hacking Techniques of 2008 (Official)

We searched far and wide collecting as many Web Hacking Techniques published in 2008 as possible -- ~70 in all. These new and innovative techniques were analyzed and ranked based upon their novelty, impact, and pervasiveness. The 2008 competition was exceptionally fierce and our panel of judges ([Rich Mogull](#), [Chris Hoff](#), [H D Moore](#), and [Jeff Forristal](#)) had their work cut out for them. For any researcher, or "breaker" if you prefer, simply the act of creating something unique enough to appear on the list is no small feat. That much should be considered an achievement. In the end, ten Web hacking techniques rose head and shoulders above.

Supreme honors go to Billy Rios, Nathan McFeters, Rob Carter, and John Heasman for GIFAR! The judges were convinced their work stood out amongst the field. Beyond industry recognition, they also will receive the free pass to [Black Hat USA 2009](#) (generously sponsored by Black Hat)! Now they have to fight over it. ;)

Congratulations to all!

Coming up at [SnowFROC AppSec 2009](#) and [RSA Conference 2009](#) it will be my great privilege to highlight the results. Each of the top ten techniques will be described in technical detail for how they work, what they can do, who they affect, and how best to defend against them. The opportunity provides a chance to get a closer look at the new attacks that could be used against us in the future -- some of which already have.

Top Ten Web Hacking Techniques of 2008!

1. GIFAR

(Billy Rios, Nathan McFeters, Rob Carter, and John Heasman)

2. Breaking Google Gears' Cross-Origin Communication Model

(Yair Amit)

3. Safari Carpet Bomb

(Nitesh Dhanjani)

4. Clickjacking / Videojacking

(Jeremiah Grossman and Robert Hansen)

5. A Different Opera

(Stefano Di Paola)

6. Abusing HTML 5 Structured Client-side Storage

(Alberto Trivero)



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

 Posts

 Comments

7. Cross-domain leaks of site logins via Authenticated CSS

(Chris Evans and Michal Zalewski)

8. Tunneling TCP over HTTP over SQL Injection

(Glenn Wilkinson, Marco Slaviero and Haroon Meer)

9. ActiveX Repurposing

(Haroon Meer)

10. Flash Parameter Injection

(Yuval Baror, Ayal Yogev, and Adi Sharabani)

The List

1. CUPS Detection
2. CSRFing the uTorrent plugin
3. Clickjacking / Videojacking
4. Bypassing URL Authentication and Authorization with HTTP Verb Tampering
5. I used to know what you watched, on YouTube (CSRF + Crossdomain.xml)
6. Safari Carpet Bomb
7. Flash clipboard Hijack
8. Flash Internet Explorer security model bug
9. Frame Injection Fun
10. Free MacWorld Platinum Pass? Yes in 2008!
11. Diminutive Worm, 161 byte Web Worm
12. SNMP XSS Attack (1)
13. Res Timing File Enumeration Without JavaScript in IE7.0
14. Stealing Basic Auth with Persistent XSS
15. Smuggling SMTP through open HTTP proxies
16. Collecting Lots of Free 'Micro-Deposits'
17. Using your browser URL history to estimate gender
18. Cross-site File Upload Attacks
19. Same Origin Bypassing Using Image Dimensions
20. HTTP Proxies Bypass Firewalls
21. Join a Religion Via CSRF
22. Cross-domain leaks of site logins via Authenticated CSS
23. JavaScript Global Namespace Pollution
24. GIFAR
25. HTML/CSS Injections - Primitive Malicious Code
26. Hacking Intranets Through Web Interfaces
27. Cookie Path Traversal
28. Racing to downgrade users to cookie-less authentication
29. MySQL and SQL Column Truncation Vulnerabilities
30. Building Subversive File Sharing With Client Side Applications
31. Firefox XML injection into parse of remote XML
32. Firefox cross-domain information theft (simple text strings, some CSV)
33. Firefox 2 and WebKit nightly cross-domain image theft
34. Browser's Ghost Busters
35. Exploiting XSS vulnerabilities on cookies
36. Breaking Google Gears' Cross-Origin Communication Model
37. Flash Parameter Injection
38. Cross Environment Hopping
39. Exploiting Logged Out XSS Vulnerabilities
40. Exploiting CSRF Protected XSS

41. ActiveX Repurposing, (1, 2)
42. Tunneling tcp over http over sql-injection
43. Arbitrary TCP over uploaded pages
44. Local DoS on CUPS to a remote exploit via specially-crafted webpage (1)
45. JavaScript Code Flow Manipulation
46. Common localhost dns misconfiguration can lead to "same site" scripting
47. Pulling system32 out over blind SQL Injection
48. Dialog Spoofing - Firefox Basic Authentication
49. Skype cross-zone scripting vulnerability
50. Safari pwns Internet Explorer
51. IE "Print Table of Links" Cross-Zone Scripting Vulnerability
52. A different Opera
53. Abusing HTML 5 Structured Client-side Storage
54. SSID Script Injection
55. DHCP Script Injection
56. File Download Injection
57. Navigation Hijacking (Frame/Tab Injection Attacks)
58. UPnP Hacking via Flash
59. Total surveillance made easy with VoIP phone
60. Social Networks Evil Twin Attacks
61. Recursive File Include DoS
62. Multi-pass filters bypass
63. Session Extending
64. Code Execution via XSS (1)
65. Redirector's hell
66. Persistent SQL Injection
67. JSON Hijacking with UTF-7
68. SQL Smuggling
69. Abusing PHP Sockets (1, 2)
70. CSRF on Novell GroupWise WebAccess

Posted by [Jeremiah Grossman](#) at [6:30 AM](#)

26 comments:

Arshan Dabirsiaghi said...



congrats

and BOOOOOO

February 23, 2009 at 6:58 AM

Jeremiah Grossman said...



LOL. Do a mapping to source code solutions if you like. :)

February 23, 2009 at 7:23 AM

Nate McFeters said...



Thanks for the recognition!

We'll have a Rock Band 2 guitar competition to see who the ultimate winner of the BH ticket is.

-Nate

February 23, 2009 at 9:02 AM

Jeremiah Grossman said...



hahah, take a picture! Hackers playing Rock Band. Will rock for BH ticket! :)

February 23, 2009 at 9:04 AM

CG said...



how come the activeX repurposing has 3 links at the bottom but only 1 at the top?

February 23, 2009 at 9:07 AM

Jeremiah Grossman said...



I limited all the top ten links to one for cosmetic purposes. Had planned to add any useful additional reference links to the index as they come up.

February 23, 2009 at 9:10 AM

Anonymous said...

congratulations all, although I do not completely agree :)

February 23, 2009 at 10:29 AM

Anonymous said...

And the real winner was....

http://documents.iss.net/whitepapers/IBM_X-Force_WP_final.pdf

February 23, 2009 at 12:27 PM

Nate McFeters said...



I agree with Gareth on that one... while I was glad to win the pwnie this year, I mentioned at the show the only reason Dowd lost out was cause he was a judge.

He easily could have won this, and def. should've been on the list.

To me, the only reason GIFAR was all that interesting was that it provided a way to compromise something more than just user data without a memory corruption.

February 23, 2009 at 12:35 PM

kuza55 said...



Eh, I was planning to ignore this, since I always disagree with these lists, but #2 just makes me bitter since they didn't even realise the full potential of it with Firefox/E4X (slides 26-27 here: <http://powerofcommunity.net/poc2008/kuza55.pdf> and since it seems they're hosting my old slides there, there are some slides with more details (slides 54-57) here: http://www.ruxcon.org.au/files/2008/Attacking_Rich_Internet_Applications.pdf)

P.S. Congrats Billy, Nate, Rob & John :) Though given your employers usually pay for blackhat tickets, I'm not really sure what the benefit there is ;p

February 23, 2009 at 2:43 PM

Nate McFeters said...



Thanks for the congrats Kuza! Yeah, it's tough economic times though man, you never know... that ticket might come in handy.

Maybe we'll donate it to you though.... of course, you'd still have to get the flight covered.

February 23, 2009 at 3:00 PM

Marinus said...



Good to see some South Africans on the list. Kudos guys!

February 24, 2009 at 1:41 AM

Vincent said...



And ACSRF ? :)

<http://esl.epitech.eu/acsrp>

February 24, 2009 at 9:07 AM

MustLive said...



I congratulate the winners - the authors of GIFAR. And all authors of top 10 web hacking techniques.

GIFAR is nice, but all top 10 techniques are nice. All web hacks of 2008 are interesting.

February 24, 2009 at 11:25 AM

Nate McFeters said...



Thanks MustLive!

I agree, I think the best part of this is not some award, but the acknowledgement of some real interesting research all in one place.

-Nate

February 24, 2009 at 11:41 AM

Anonymous said...

congrats Nate and company! there were very interesting submissions, although i must say im surprised by some of the appearances in the top 10 list.

February 24, 2009 at 2:02 PM

Erick Lee said...



This comment has been removed by the author.

February 24, 2009 at 2:20 PM

Erick Lee said...



Congrats...Not sure I agree with the top 10, but then putting a list together that security professional on agree is an exercise in futility.

February 24, 2009 at 2:27 PM

Rob said...



thx everybody. there were a lot of great techniques this year. glad i wasn't a judge ;)

February 24, 2009 at 2:48 PM

Unknown said...



Congrats to all.

The gifar hack is really very interesting thinking.

My choice for the "chutzpah" award (if there was such a thing) is the CSS hack (number 7). It is very simple and effective.

South Africa has about 4 banks and I actually implemented

number 7 in about half an hour, during a meeting that was very boring.

And it amazed people. (Actually shocked ... which is good for Security awareness)

February 25, 2009 at 3:11 AM

Anonymous said...

Hey Jeremiah. Excellent read, I'm glad our work impressed the panel! As an aside, and completely vain attempt to get my name higher in Google rankings (who does that? ;)) could you s/Willinson/Wilkinson for the SensePost number 8 entry? Might also be more useful to link to www.sensepost.com/research/reDuh/ instead of the direct link to the tool, as there's some blarb to read there.

Glenn

February 25, 2009 at 3:46 AM

Jeremiah Grossman said...



@Glenn, first great work on the research and congratulations on making the list! Made the corrections you specified, sorry for the delay.

February 25, 2009 at 8:23 AM

Anonymous said...

@Jeremiah. Thanks for the kind words and update!

Glenn

February 25, 2009 at 10:44 AM

Vincetastic said...



This is an awesome top ten list Jeremiah, really interesting hacks. You can post this to our site <http://www.toptentopten.com/> and then link back to your site. We are looking for content and in return our users will track back to your site. The coolest feature is you can let other people vote on the rankings of your list.

February 25, 2009 at 3:32 PM

Anonymous said...

Thanks for sharing results, Jeremiah. Great resources in 1 place. I shared a link to here on Twitter too (smile). Hope your traffic surges; good stuff for professionals.

@CheriSigmon

February 25, 2009 at 9:04 PM

Jeremiah Grossman said...



@Rob, me too! So many great techniques. You know there has got to be some sick combos one can do -- especially considering all the stuff from the last two years.

@Cheri, thank you, glad you liked it. It is good to have all this stuff in one spot.

February 25, 2009 at 9:07 PM

[Post a Comment](#)

[Newer Post](#)[Home](#)[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)